

SHELL we dance

클라우드 기반 핀테크 플랫폼 시나리오 모의해킹



Team. 모의해킹



Contents

Chapter 1	프로젝트 개요	
	팀원소개	3
	WBS	4
	프로젝트 선정 개요	5
	타겟 기업 분석	6

Chapter 2	개발 및 진단	
	아키텍처	7
	기능 구성	8
	취약점 진단	9
	Web 진단 결과	12
	App 진단 결과	13

Chapter 3	시나리오 모의해킹	
	협력사망 경유를 통한 공급망 연쇄침투	14
	연쇄 침투를 통한 지능형 보이스피싱 공격	25

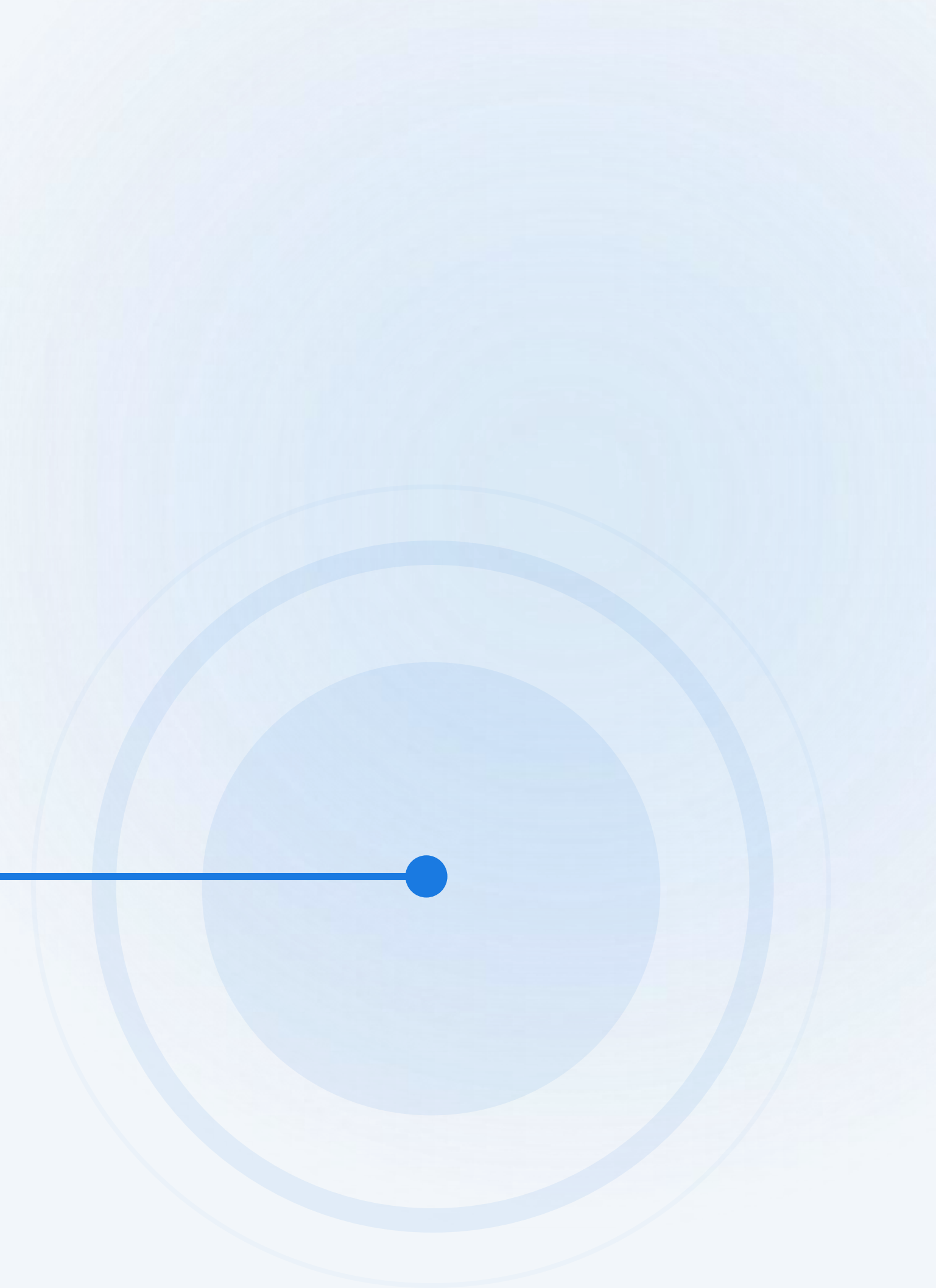
Chapter 4	보안 대책 및 향후 계획	
	보안 대책	30
	향후 계획	36

CHAPTER —

01

프로젝트 개요

- 팀원소개
- WBS
- 프로젝트 선정 개요
- 타겟 기업 분석



팀원 소개

✓ 팀장

백승빈

보안 프로그램
공급망 공격



✓ 팀원

최상훈

APP 개발 / AWS
공급망 공격



✓ 팀원

서정우

Frontend 개발
공급망 공격



✓ 팀원

손지선

Frontend 개발
보이스피싱



✓ 팀원

성준모

Backend 개발
보이스피싱



✓ 팀원

표민우

시나리오 / AWS
보이스피싱



WBS

	W1	W2	W3	W4	W5	W6	W7	W8
현황분석								
프론트엔드 개발 (웹 / 모바일)								
백엔드 개발								
클라우드 구축								
취약점 진단								
시나리오 기획								
추가 개발								
시나리오 모의해킹								
결과 보고서								
최종 PPT 작성								

프로젝트 선정 개요

✓ 1. 인프라 패러다임 전환

망분리 망신 경계 및 우회 공격 현실화

2026.03.04

금융보안원 "망분리도 안전지대 아니다"
구조적 취약점 악용한 우회 공격 가능성 경고

내부 데이터 유출·업무망 침투·클라우드 경유 유출 등 3가지 공격 시나리오 공개
망분리 망신 벗어나 모의해킹 기반 선제적 보안 대응 필요

클라우드 연동 구간 및 서드파티 솔루션을
징검다리로 삼아 내부 핵심망으로
침투하는 **우회 공격** 급증

출처 : <https://www.dailysecu.com/news/articleView.html?idxno=205534>

✓ 2. 금융 타깃 위협 심화

금융 데이터의 치명성과 표적화

2025.10.24

"금융권, 6년간 해킹 31건·전산장애 1,884건"
금감원 자료로 본 금융권 보안 실태

패치·취약점 관리, 외부 위탁·연계시스템 보안수준 점검이 핵심 과제로 부상
2025년 1~9월에만 금융권 해킹 사고 8건 보고돼

막대한 피해 규모 발생,
킬체인 기반 실전 모의 해킹 필수

출처 : <https://www.dailysecu.com/news/articleView.html?idxno=201714>

✓ 3. 공격 표면 확장

오픈 API 및 MSA 공급망 리스크

2025.11.10

"금융권, 디지털 혁신 속 보안 리스크 급증
통합적 대응 전략 시급"

오픈 banking·BaaS·AI 도입 확대 속 '공격 표면' 급격히 확장
"기술 채택만으로는 부족...보안을 경영 전략의 축으로 재정립해야"

보안이 취약한 제 3자 핀테크 플랫폼이
대형 금융사 공격의 **우회 경로로 악용**

출처 : <https://www.dailysecu.com/news/articleView.html?idxno=202199>

타겟 기업 및 비즈니스 환경 분석



Shell Bank_



인프라 전환기

500만 가입자의 대규모 트래픽을 유연하게 처리하기 위해, 기존 온프레미스 환경에서 벗어나 AWS 퍼블릭 클라우드로 전면 마이그레이션을 진행하고 있음



필수적인 외주 인프라 연동

전체 고객 중 15%에 달하는 전자금융고지 미동의 고객을 위해, 실물 인쇄 및 우편 발송을 전담하는 외부 대행업체와 본사 DMZ망을 상시 연동하여 운영하고 있음



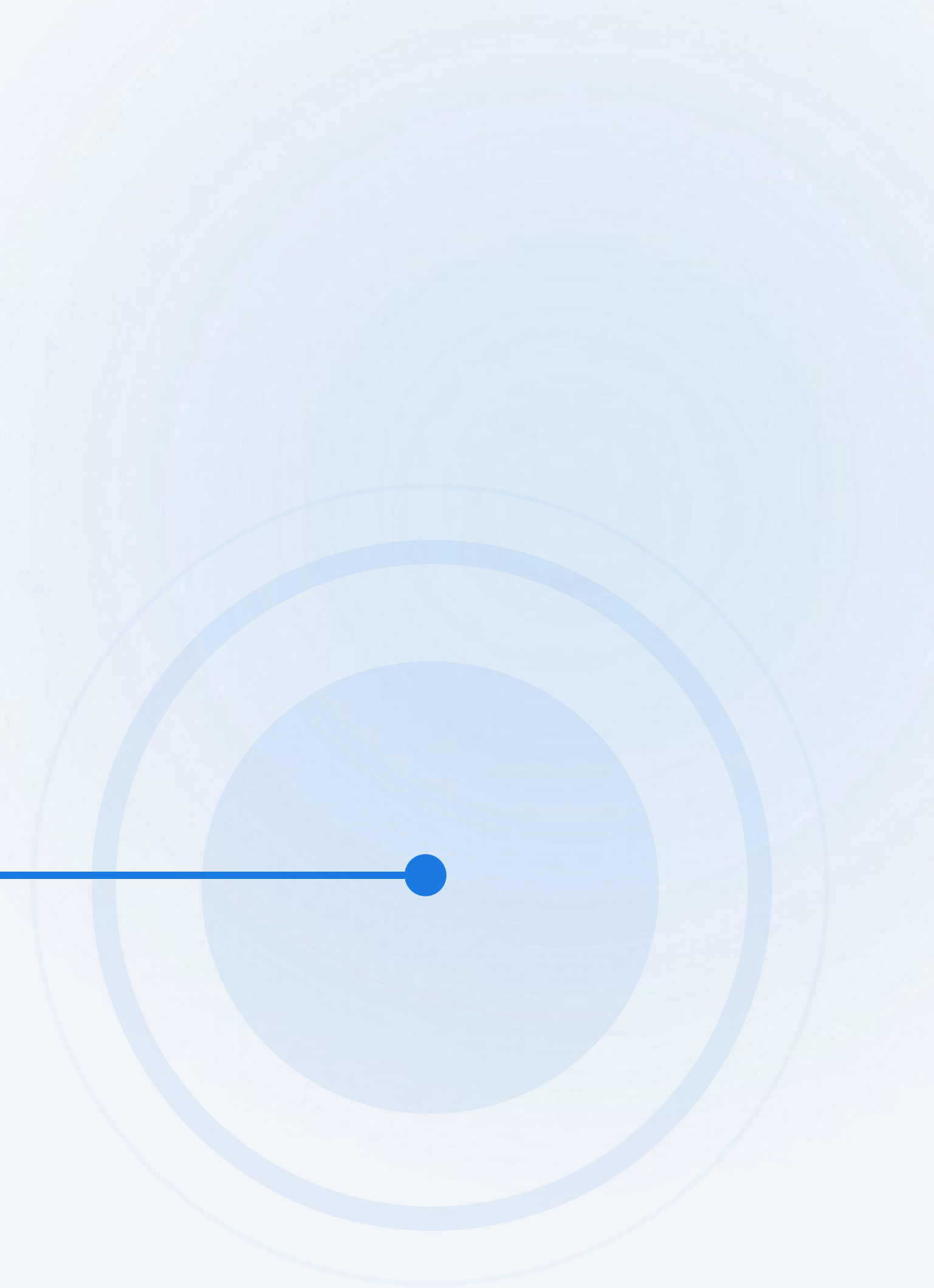
사용자 경험 중심의 개발 자율성

가입자들에게 편한 비대면 금융 경험을 제공하기 위해, Web 및 App 개발자들에게 업무 자율성과 배포 권한을 부여하고 있음

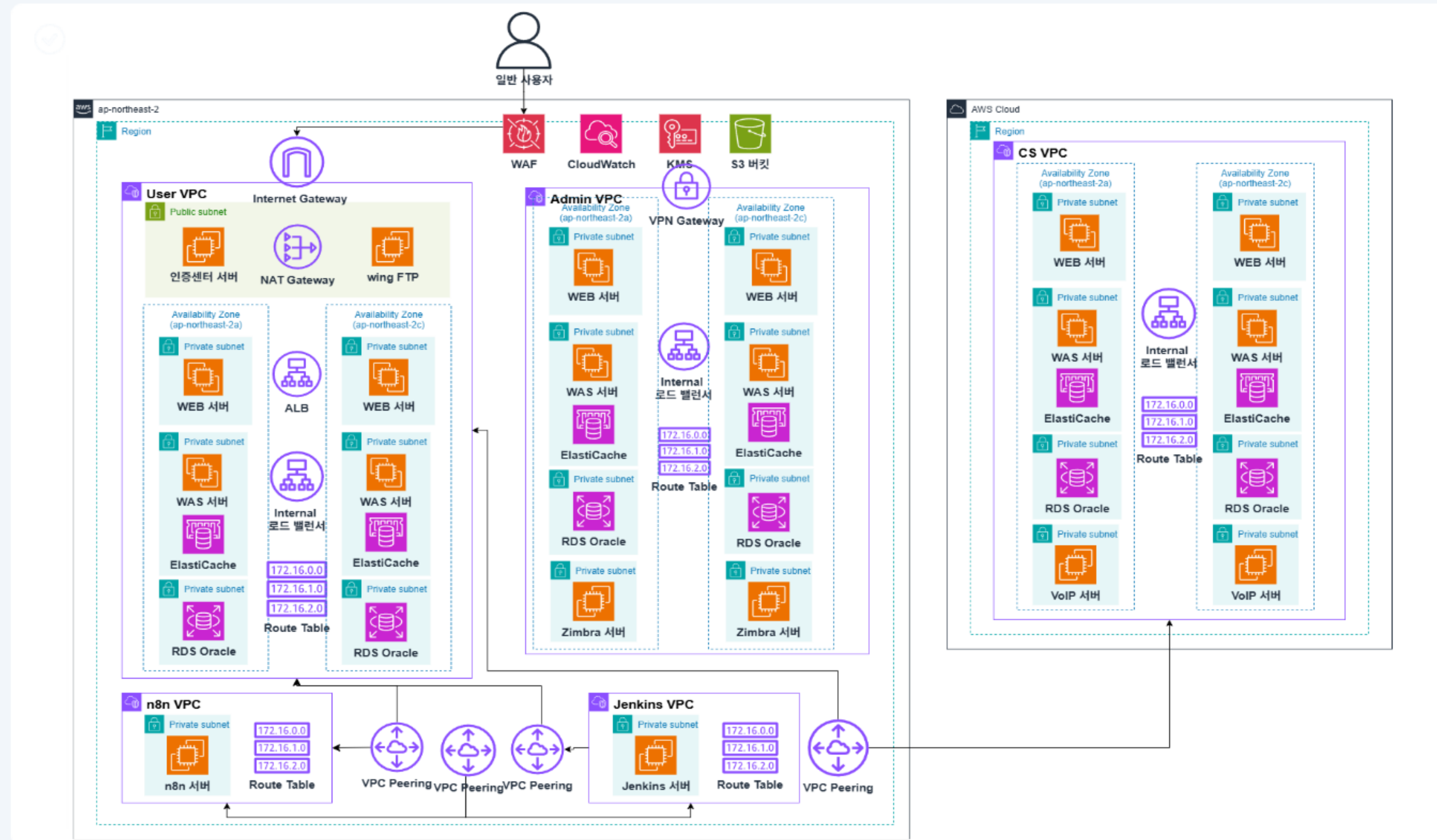
CHAPTER —

02 개발 및 진단

- 아키텍처
- 기능 구성
- 취약점 진단
- Web 진단 결과
- App 진단 결과



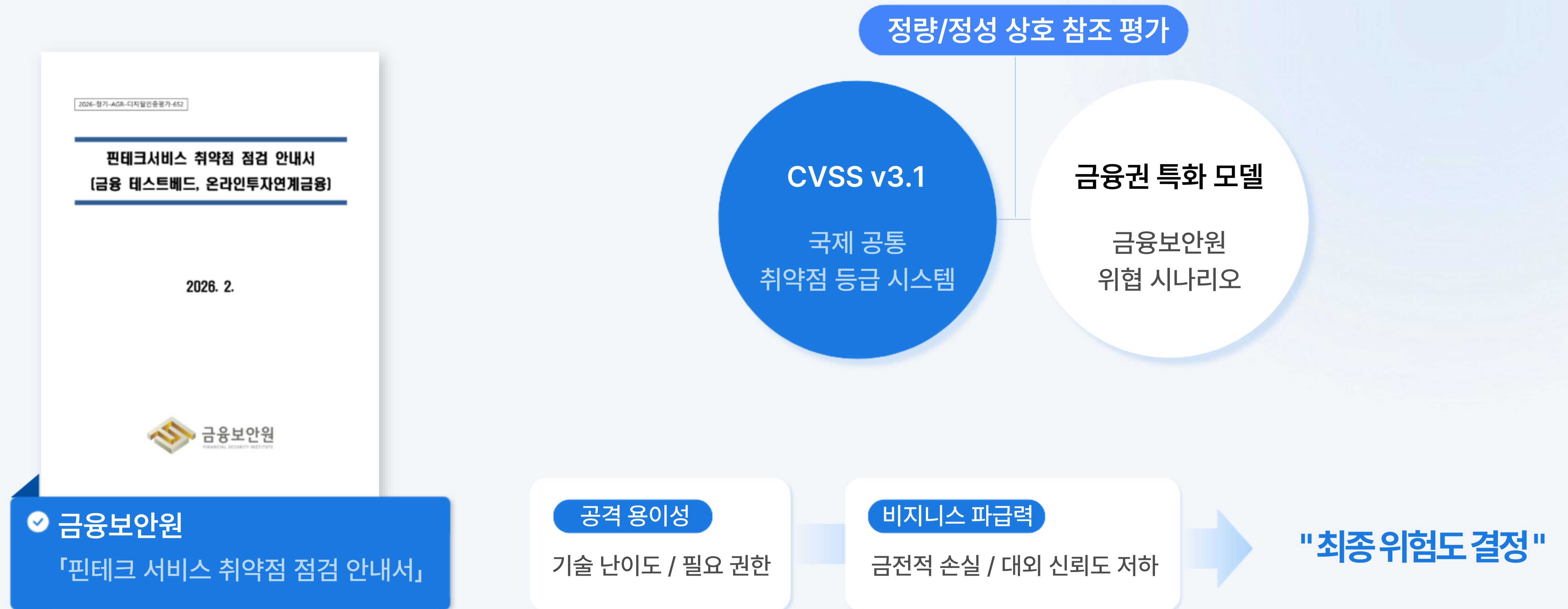
아키텍처



기능 구성



취약점 진단 기준 선정



Web 취약점 진단 보고서

Shell bank 웹 서비스 취약점진단 결과보고서

Confidential

Shell bank 웹 서비스 취약점진단 결과보고서

2026. 04. 08.

Shell bank 웹 서비스 취약점진단 결과보고서	Shell We Dance
	2026. 04. 08

용자 편의성을 극대화하기 위해 복잡한 금융 로직을 웹과 모바일 앱 환경으로 인프라 중심의 보안 점검으로는 식별하기 어려운 '비즈니스 로직 결함'이라는 합니다. 공격자는 이제 서버의 취약점을 찾는 것에 그치지 않고, 설계상의 허점을 찾아거나 정상적인 금융 프로세스를 무력화하는 방식을 취하고 있습니다. '스프링 부트'의 '스프링' 프로젝트의 핵심 과제로, 전통적 금융의 경계를 허물고 고속 성장의 보안 실효성을 검증하는 데 그 목적이 있습니다.

URL	서비스명
29pentest-alb-179768306.ap-northeast-2.elb.amazonaws.com/home	Shell bank

[표] 1. 진단대상

항목	일정
개발 계획 수립	2026.03.13 ~ 2026.03.14
취약점 점검	2026.03.15 ~ 2026.03.27
보고서 작성	2026.03.27 ~ 2026.04.08

[표] 2. 진단 일정

수행업무	E-Mail
PM	Bsb1203@gmail.com
모의해킹	frisenacib@gmail.com
모의해킹	Wjddn470900@gmail.com
모의해킹	Modev0101@gmail.com
모의해킹	Sanghun362@gmail.com
문서 정리	vyalsdn15@gmail.com

[표] 3. 진단 인력

Shell bank 웹 서비스 취약점진단 결과보고서	Shell We Dance
	2026. 04. 08

는 처리 과정 등에서 메모리 내 평문 노출 여부를 점검

URL	파라미터
-179768306.ap-northeast-2.elb.amazonaws.com/login	

[표] 8. 메모리 내 중요정보 평문 노출

디/패스워드 입력 후 로그인한다.
ation > Storage > Session Storage > 해당 도메인 선택한다.
면 정보가 평문으로 노출되는 것을 확인할 수 있다.

Filter	Value
is://sk29pentest-alb-179768306.ap-northeast-2.elb.amazonaws.com	
ing	{"loginid":"","test":"password":"","test":"","purpose":"","login"}
No value selected Select a value to preview	

그림] 1. 로그인 페이지의 개발자 도구

Shell bank 웹 서비스 취약점진단 결과보고서	Shell We Dance
	2026. 04. 08

가능성

도메인을 서버 설정에서 미리 지정된 안전한 도메인으로 한정
https://...) 대신 내부 경로(/dashboard 등)만 허용하도록 로직을 수정
신 사전에 정의된 ID(예: next=1)로 관리하여 목적지 주소 조작을 원천

경우, 사용자에게 "외부 사이트로 연결됩니다"라는 안내 문구를 명시

owered-By 등의 헤더에서 소프트웨어 이름과 버전 정보를 삭제 또는

내부 경로가 드러나는 기본 에러 메시지 대신, 별도로 디자인된 안내

기 환영 메시지(Banner)에서 OS 및 서비스 정보를 제거
추출 수 있는 OPTIONS, TRACE 등의 HTTP 메소드를 서버 수준에서

페이지에 출력될 때 반드시 이스케이핑(Escaping) 처리되어 텍스트로만

경우, 허용된 안전한 태그와 속성만 통과시키는 필터링 라이브러리를

트만 실행하도록 하는 콘텐츠 보안 정책(CSP) 설정을 검토하여 비인가

프레임워크(React, Vue 등)의 보안 가이드라인을 준수하여 개발할 것을

SRF)

App 취약점 진단 보고서

Shell bank 앱 서비스 취약점진단 결과보고서

Confidential

Shell bank 앱 서비스 취약점진단 결과보고서

2026. 04. 08.

bank 앱 서비스 취약점진단 결과보고서	Shell We Dance
	2026. 04. 08

편의성을 극대화하기 위해 복잡한 금융 로직을 웹과 모바일 앱 환경으로
[라 중심의 보안 점검으로는 식별하기 어려운 '비즈니스 로직 결함'이라는
다. 공격자는 이제 서버의 취약점을 찾는 것에 그치지 않고, 설계상의 허점을
거나 정상적인 금융 프로세스를 무력화하는 방식을 취하고 있습니다.
모의해킹 프로젝트'의 핵심 과제로, 전통적 금융의 경계를 허물고 고속 성장
보안 실효성을 검증하는 데 그 목적이 있습니다.

APK	서비스명
ell bank Android Application	Shell bank

[표] 1. 진단대상

내역	일정
계획 수립	2026.03.13 ~ 2026.03.14
취약점 점검	2026.03.15 ~ 2026.03.27
보고서 작성	2026.03.27 ~ 2026.04.08

[표] 2. 진단 일정

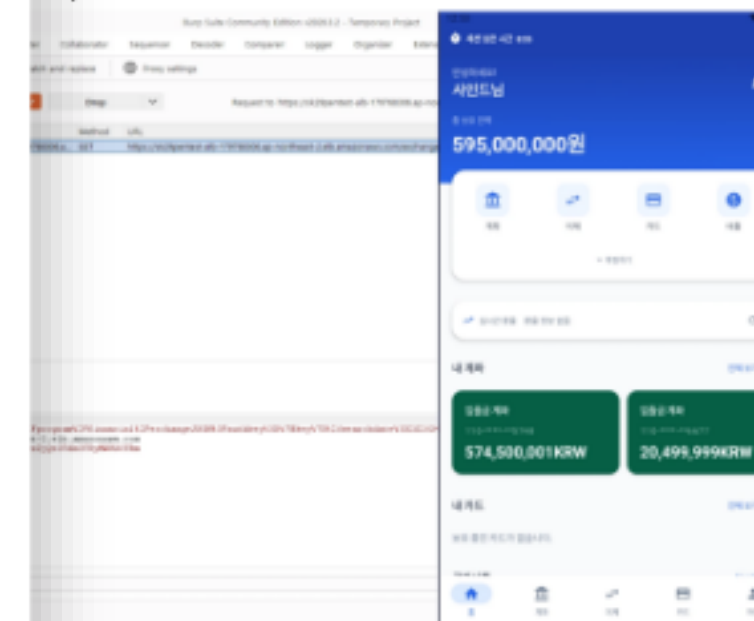
수행업무	E-Mail
모의해킹	Bsb1203@gmail.com
모의해킹	frisenacib@gmail.com
모의해킹	Wjddn470900@gmail.com
모의해킹	Modev0101@gmail.com
모의해킹	Sanghun362@gmail.com
모의해킹	vyalsdn15@gmail.com

[표] 3. 진단 인력

bank 앱 서비스 취약점진단 결과보고서	Shell We Dance
	2026. 04. 08

킬러값으로 내부 네트워크 자원에 요청을 보내도록 유도 가능한지 여부를
시스템 정보 노출 또는 내부망 접근이 가능한지지를 점검

Burp 를 이용해 잡는다



[그림] 7 패킷 캡처

```
date?uri=https://10.0.3.70:8443/actuator/health HTTP/2.0
Host: alb-179768306.ap-northeast-2.elb.amazonaws.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0
Accept: */*
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Content-Type: application/json
```

[그림] 8 Request URL 수정

날아오는 것을 확인

k 앱 서비스 취약점진단 결과보고서	Shell We Dance
	2026. 04. 08

le Play Integrity API 로 전환
고 매 API 요청마다 재검증
을 함께 수신하여 검증하는 방식 도입

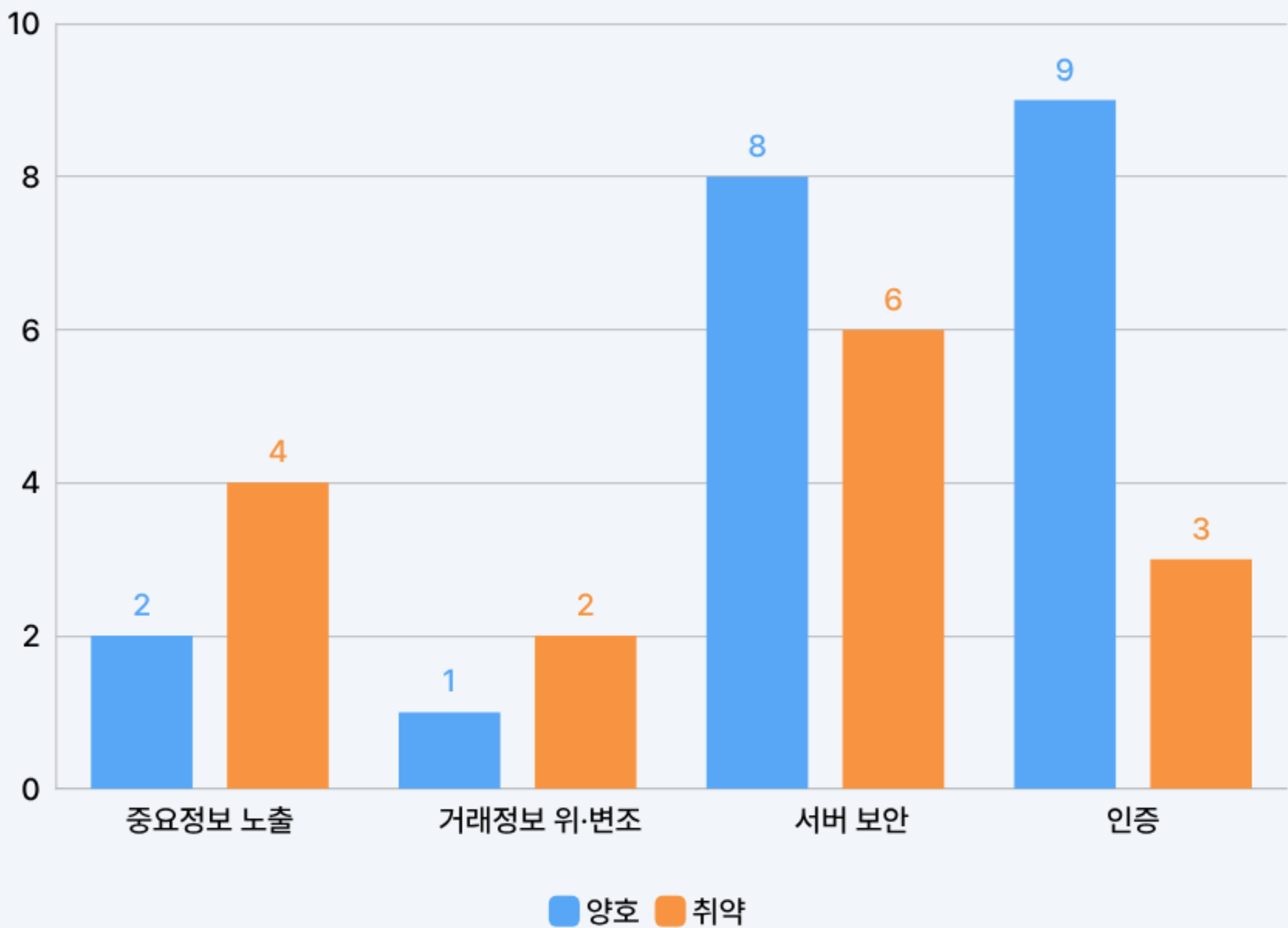
고 native 코드 내부에서 함수를 직접 종료
키지를 탐지하고 주기적인 업데이트로 우회해 대응
Integrity의 MEETS_DEVICE_INTEGRITY 결과를 루팅 탐지 보조 수단으로

지연 종료 방식을 적용하여 탐지 로직의 위치 노출 최소화
서, 재검사하여 동적 연결 시도 탐지

8 난독화 대상에서 제외되므로 문자열 암호화 적용
알도록 빌드 산출물 접근 제한
을 적용하여 빌드 시 디버그 정보와 불필요한 심볼 테이블을 제거해

적으로만 사용하는 native 함수들은 외부에 노출되지 않도록 설정
함수명 뿐만 아니라 로직 자체를 난독화

Web 진단 결과



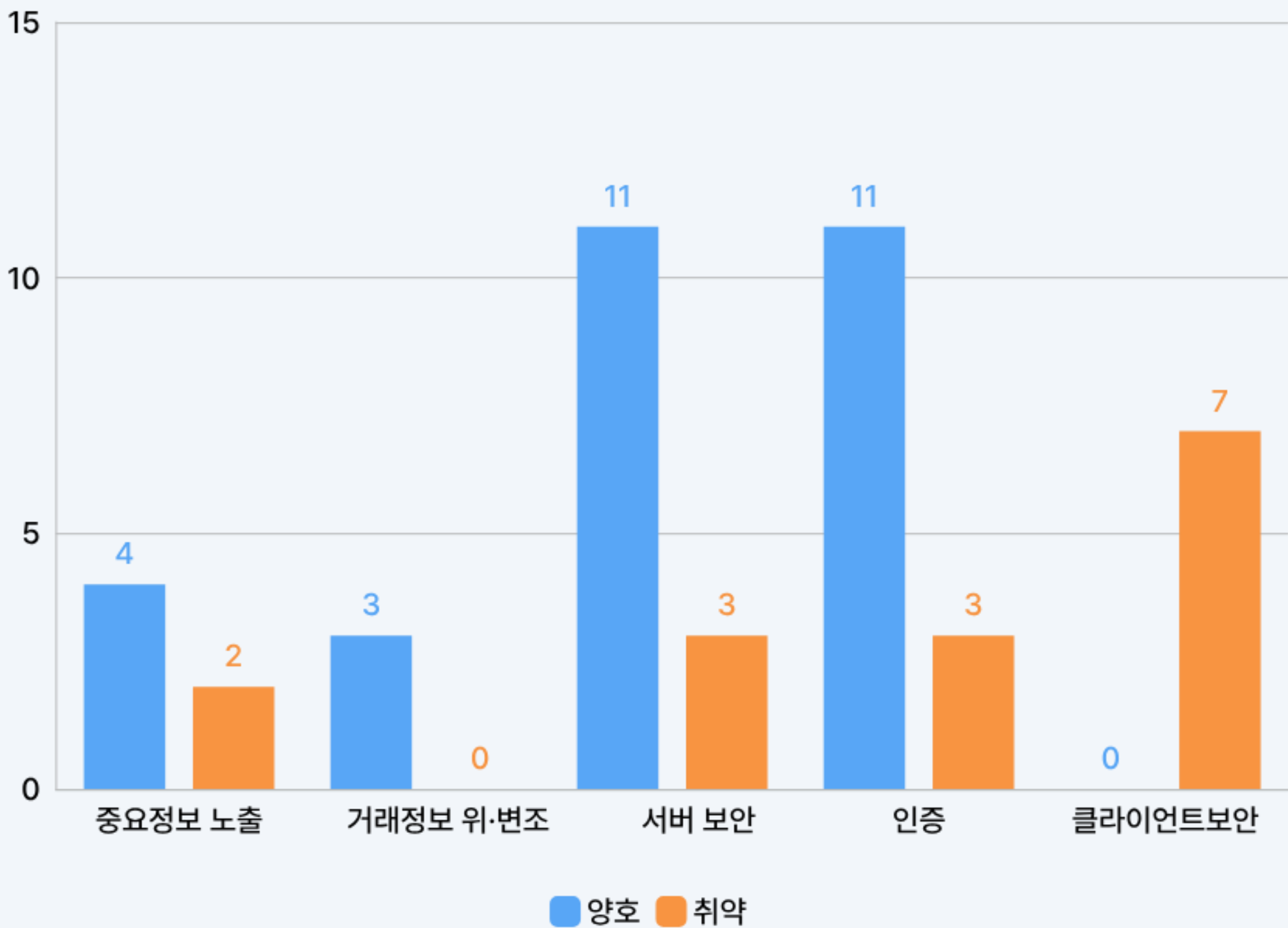
진단 항목 35개

양호 - 20개

취약 - 15개

진단 항목	위험도
메모리 내 노출	상
웹 영역 내 노출	상
파일 내 노출	상
화면 내 노출	상
금액정보 변조	상
거래정보 재사용	상
크로스사이트 스크립팅 (XSS)	상
크로스사이트 요청 변조 (CSRF)	상
서버사이드 요청 변조 (SSRF)	상
파일 업로드 취약점	상
리다이렉트 기능을 이용한 피싱 가능성	상
서버 운영정보 노출	상
비밀번호 복잡도 검증	상
쿠키정보 변조	상
비밀번호 오류 횟수 제한	상

App 진단 결과



진단 항목 44개

양호 - 29개

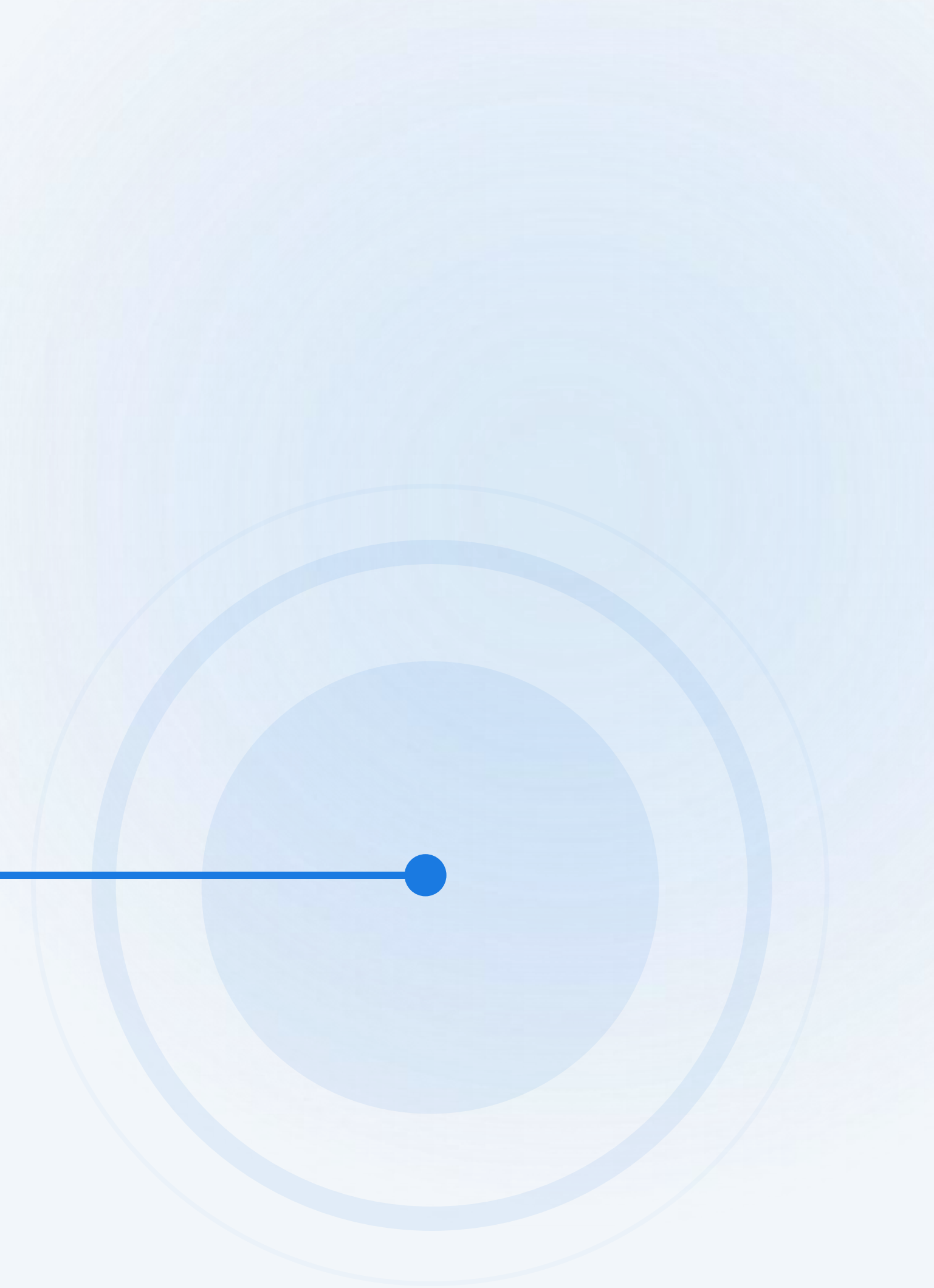
✓ 취약 - 15개

진단 항목	위험도
디버그 로그 내 노출	상
금액 정보 변조	상
크로스사이트 스크립팅(XSS)	상
크로스사이트 요청 변조(CSRF)	상
서버사이드 요청 변조(SSRF)	상
비밀번호 복잡도 검증	상
비밀번호 오류 횟수 제한	상
인증파일 변조	상
앱 위/변조 탐지 적용	상
해킹 OS 탐지 적용	상
안티디버깅 적용	상
코드 난독화 적용	상
안티바이러스 적용	상
이벤트 기반 생체 인증 API 서버 검증	상
네트워크 트래픽 내 인증서 핀닝 적용 여부	상

CHAPTER —

03 시나리오 모의해킹

- 협력사망 경유를 통한 공급망 연쇄 침투
- 연쇄 침투를 통한 지능형 보이스피싱 공격



협력사망 경유를 통한 공급망 연쇄 침투

✓ 시나리오 요약

협력사망을 최초 침투 경로로 삼아, 망 분리 환경의 파일 교환 접점(DMZ)을 거쳐
본사 내부망과 CI/CD 파이프라인까지 연쇄적으로 장악하는 End-to-End 공격 시나리오

1

초기 정찰 및
협력사망 침투

3

내부망 횡적
이동

5

GitLab 액세스
토큰 탈취

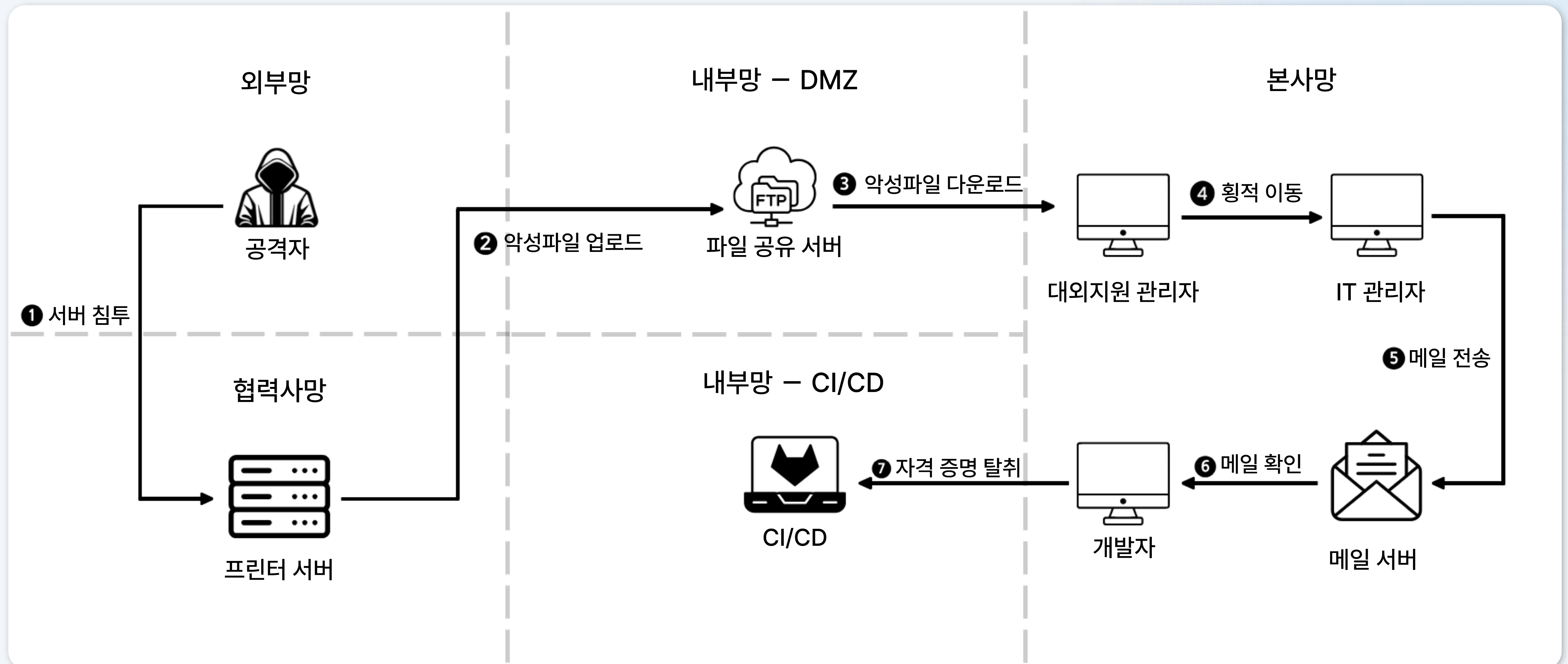
2

파일 서버 장악

4

메일 서버 악용 및
브라우저 탈출

협력사망 경유를 통한 공급망 연쇄 침투



시나리오 프로그램 환경

프린트 서버(CUPS)

버전 : 1.28.15

설명 : UNIX 기반 프린터 서버

취약점: CVE-2024-47176

CVE-2024-47076

CVE-2024-47175

CVE-2024-47177

파일 서버(WingFTP)

버전 : 7.4.3

설명 : 오픈 소스 파일서버

취약점 : CVE-2025-47812

OS(Windows)

버전 : Win 10 21H2 19044.1620

취약점 : CVE-2024-21412

메일 서버(Zimbra)

버전 : 10.1.10

설명 : 오픈 소스 메일서버

취약점 : CVE-2025-66376

브라우저(Chrome)

버전 : 128.0.6613.138

취약점 : CVE-2024-10230

CVE-2025-2783

협력사망 경유를 통한 공급망 연쇄 침투

CUPS : CVE-2024-47176, 47076, 47175, 47177

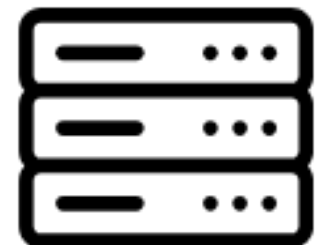


공격자

외부망



① 서버 침투



프린트 서버

협력사망

CVE 설명

CVE-2024-47176: UDP 631 무제한 수신
CVE-2024-47076: IPP 속성 검증 없이 저장
CVE-2024-47175: PPD에 악성 데이터 삽입
CVE-2024-47177: RCE

사전 지식

CUPS: 리눅스/유닉스 공통 인쇄 시스템
IPP: 인터넷 인쇄 프로토콜 (TCP/UDP 631)
PPD: 프린터 기능 기술 파일

선정 이유

Ubuntu, Debian, Fedora 기본 탑재
인터넷 노출 취약 시스템: 최대 30만 대 추정
사전 인증 불필요 (UDP 패킷 1개)
코드 통합 과정에서의 보안 검토 부재

협력사망 경유를 통한 공급망 연쇄 침투

CUPS : CVE-2024-47176, 47076, 47175, 47177

체인 전체 흐름

공격자 → UDP 패킷 전송 → 피해 서버 포트 631



피해 서버 cups-browsed → 공격자의 가짜 IPP 서버에 자동 접속
공격자 IPP 서버 → 악성 프린터 속성값 응답



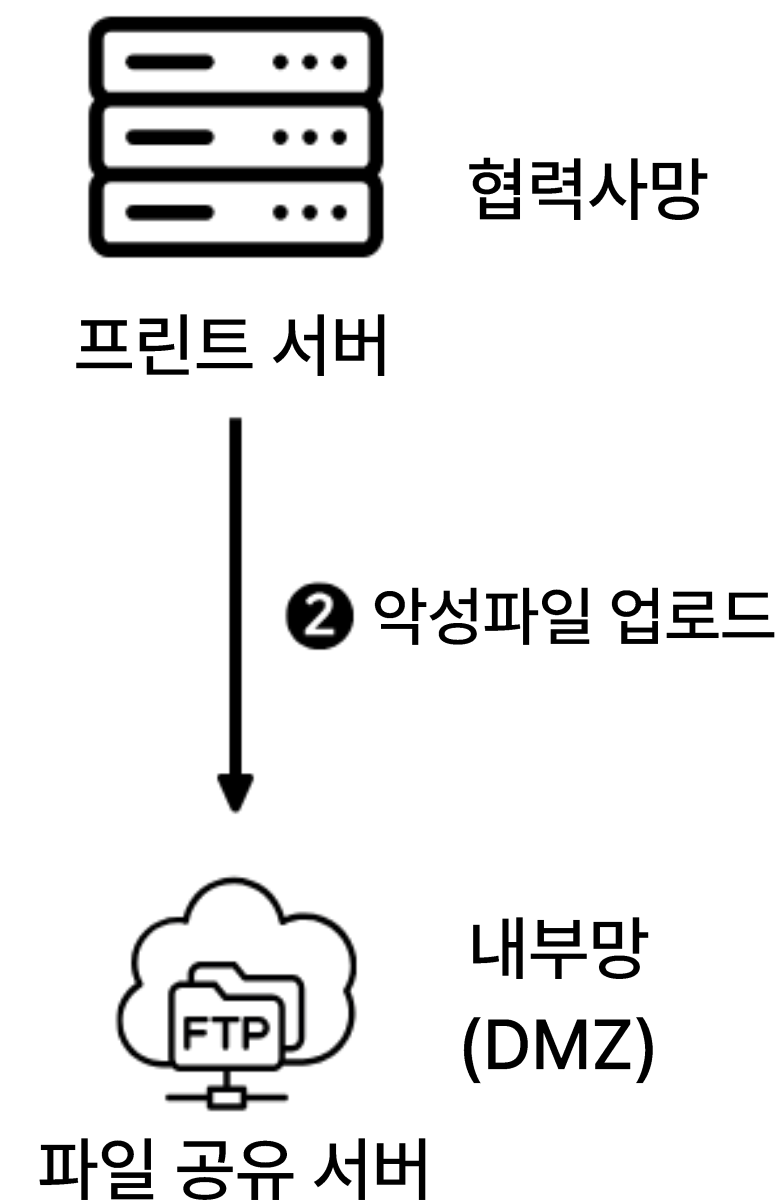
CUPS가 가짜 프린터 PPD 파일 생성
악성 데이터가 PPD 파일 내 FoomaticRIPCommandLine에 삽입됨



사용자가 가짜 프린터로 인쇄 시도
foomatic-rip이 PPD 내 악성 명령어를 셸에서 실행

협력사망 경유를 통한 공급망 연쇄 침투

WingFTP : CVE-2025-47812



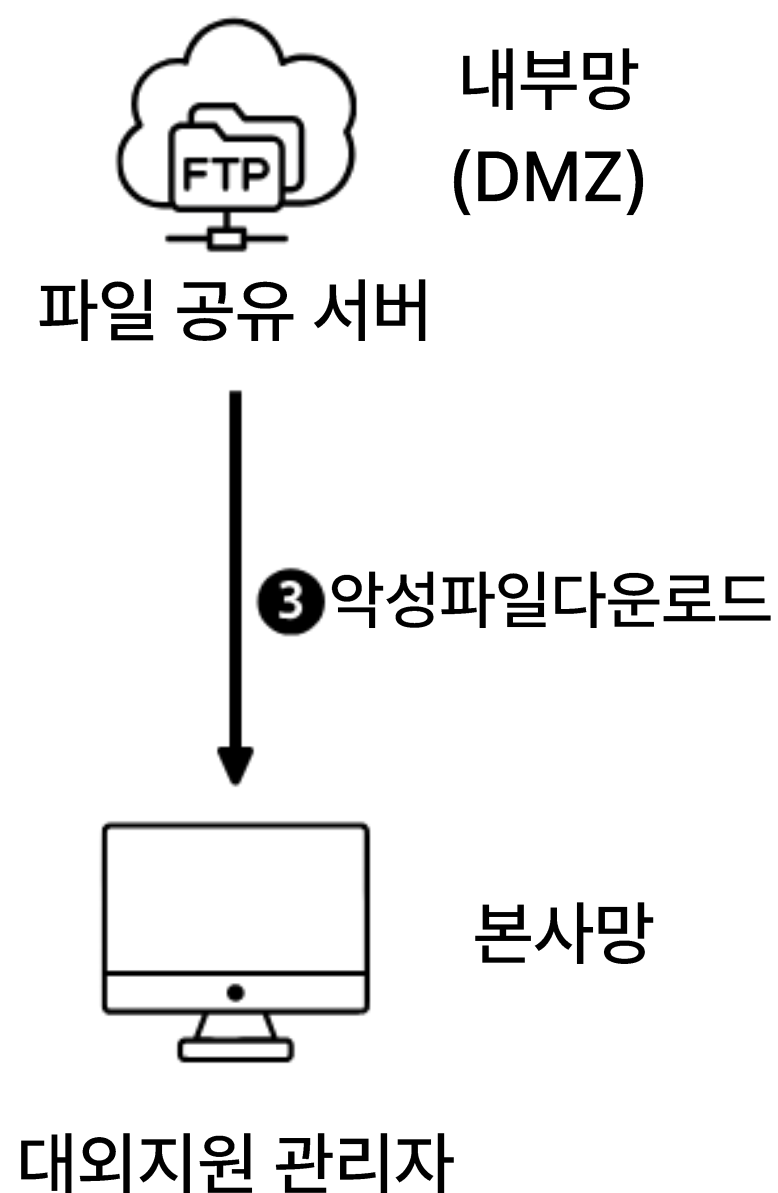
CVE 설명 WingFTP 서버에서 발생하는 인증 없는 원격 코드 실행 취약점

사전 지식 Null Byte 인젝션 원리: 문자열 끝을 의미하는 널 바이트를 악용하여, 시스템의 파일 확장자나 검증 로직을 우회
세션 직렬화/역직렬화: 데이터 객체를 저장/전송하기 위해 바이트 형태로 변환하고 다시 복원하는 과정
Lua 스크립트: 어플리케이션에 내장하기 쉬운 경량 스크립트 언어

선정 이유 본사-협력사 간 인쇄 업무용 파일 서버 타겟팅 -> 인증 없는 RCE
최종 타겟 연쇄 침투를 위한 내부망 초기 거점 장악

협력사망 경유를 통한 공급망 연쇄 침투

Windows : CVE-2024-21412



CVE 설명

Windows Defender SmartScreen 우회 취약점
사용자가 악성 파일을 실행할 때 나타나는 보안 경고창을 무력화 함

사전 지식

MotW: 외부 신뢰할 수 없는 영역에서 다운로드한 파일에 윈도우가 부여하는 출처 식별 태그

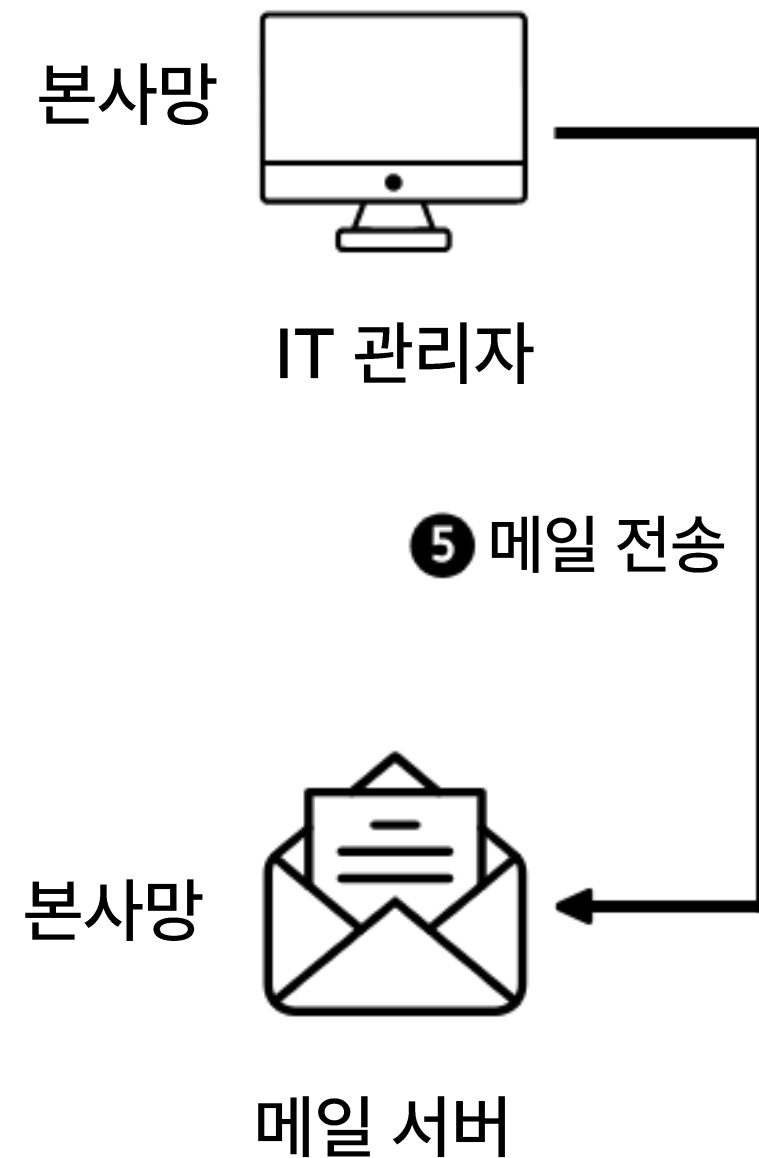
SmartScreen: MotW 태그가 붙은 파일을 실행 시 안전성을 분석하여 악성일 경우 실행 차단하고 경고창을 띄우는 윈도우 방어 메커니즘

선정 이유

Water Hydra 등 실제 APT 공격 그룹이 외환/금융권 타겟을 공격 시, 보안 솔루션 탐지를 피하기 위해 적극적으로 악용한 대표 사례임

협력사망 경유를 통한 공급망 연쇄 침투

Zimbra : CVE-2025-66376



CVE 설명 Zimbra 웹메일 시스템에서 입력값 필터링 미흡으로 발생한 Stored XSS 취약점
공격자가 메일 본문에 악성 스크립트를 삽입하여 실행할 수 있는 환경을 제공

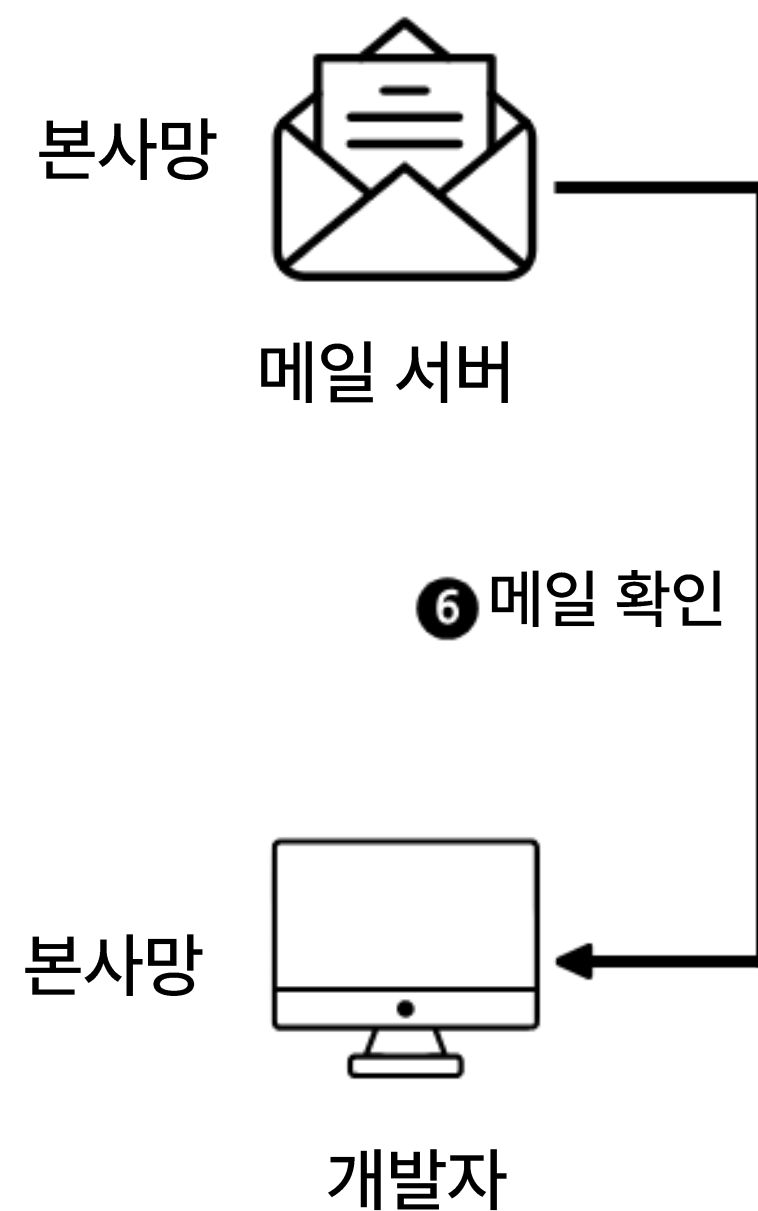
사전 지식 스크립트: 브라우저가 웹페이지를 열 때 자동으로 실행되는 코드. 버튼 클릭, 팝업 같은 동작을 만들어냄

웹 필터링: 사용자가 입력한 값에서 위험한 코드를 걸러내는 보안 장치

선정 이유 러시아-우크라이나 전쟁 중 러시아 APT28이 수행한 고스트메일 작전에서 실제로 사용된 취약점
우크라이나 정부를 대상으로 Zimbra 메일을 통해 데이터를 탈취함
이 단계의 목표는 이후 악성 코드가 실행될 수 있는 환경을 만드는 것

협력사망 경유를 통한 공급망 연쇄 침투

V8 엔진 : CVE-2024-10230



CVE 설명

크롬 V8 엔진의 타입 혼동 취약점
공격자가 크롬 메모리를 임의로 읽고 쓸 수 있는 권한을 획득

동작 방식

직접 빌드 한 WebAssembly 모듈로 타입을 잘못 판단하게 유도
기존의 Read/Write 함수를 사용자 정의 함수로 대체
이 과정에서 V8 샌드박스 탈출 후 임의 코드 실행 권한 획득

샌드박스

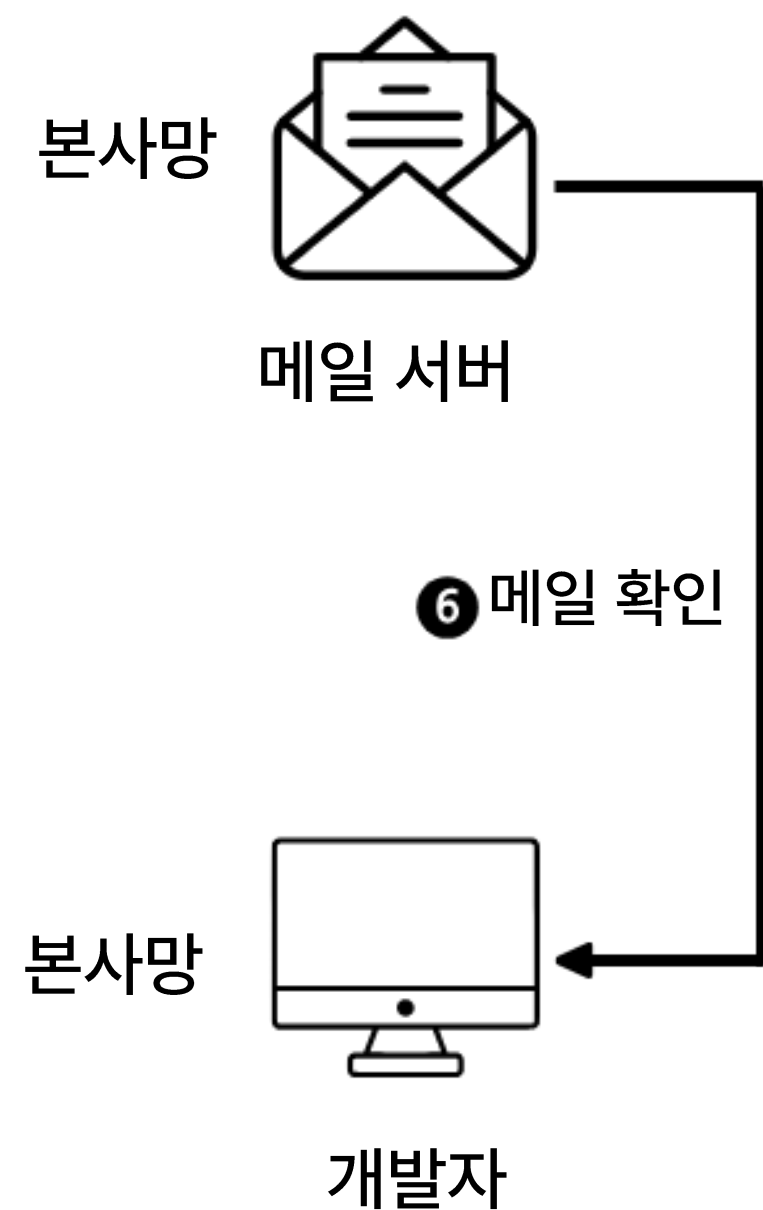
웹 콘텐츠를 시스템 리소스와 격리하여 실행하는 보안 장치
프로세스 간 경계를 설정하여 취약점 발생 시 피해 범위를 최소화

선정 이유

북한 해커 그룹인 시트린 슬릿이 주로 사용하는 V8 취약점과 유사한 취약점

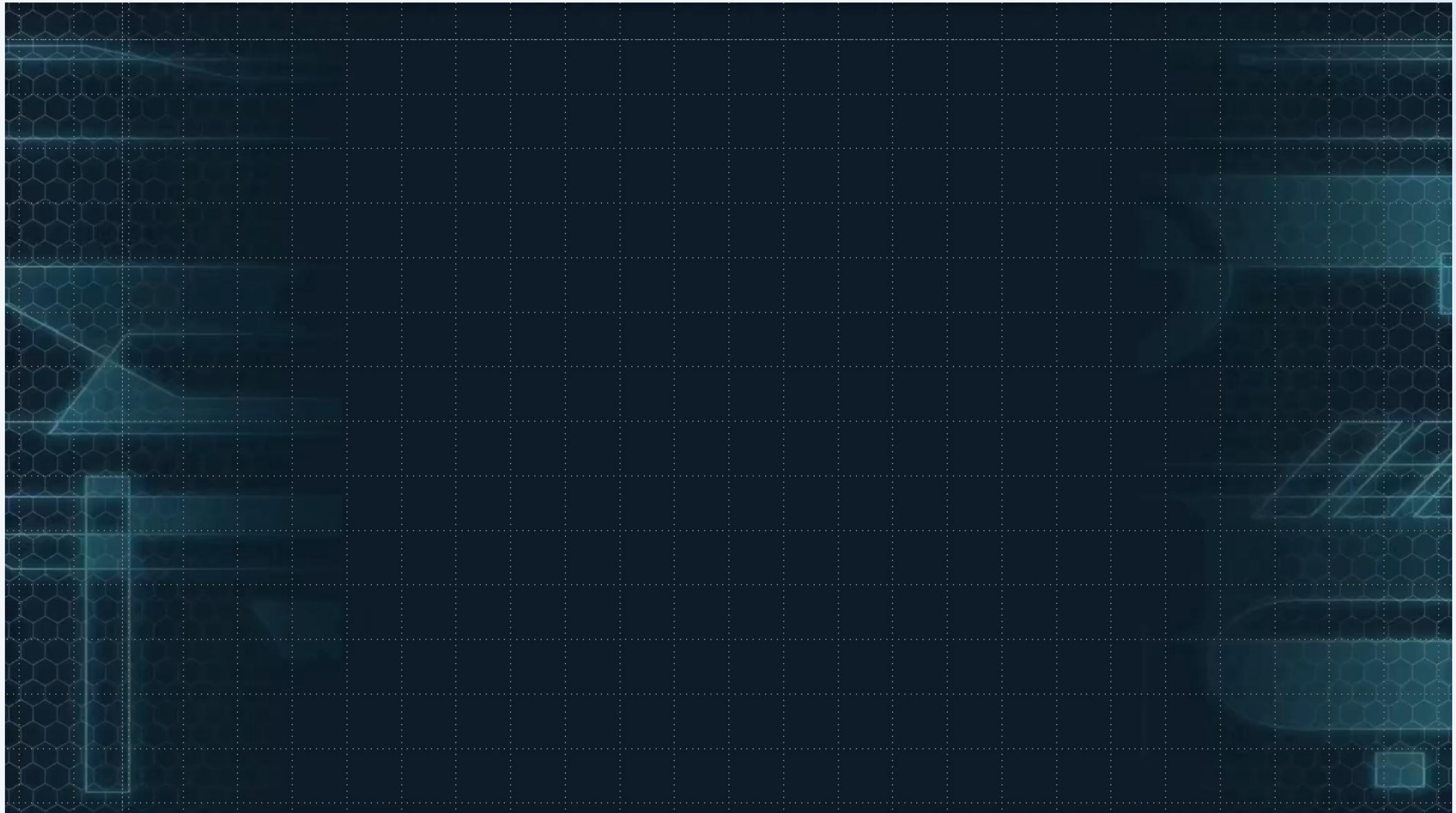
협력사망 경유를 통한 공급망 연쇄 침투

크롬 브라우저 : CVE-2025-2783



CVE 설명	Mojo IPC를 이용한 탈출 취약점 브라우저 밖 시스템 전체를 장악할 수 있게 됨
동작 방식	IPC 보안 검사 우회 → 핸들 처리 오류 → 샌드박스 탈출 → 시스템 완전 장악
사전 지식	Mojo IPC : 크롬 샌드박스과 시스템간의 통신을 위한 프로세스 간 통신 프레임워크
선정 이유	2024년 2월부터 러시아 정부를 상대로 한 공격에 사용된 취약점

협력사망 경유를 통한 공급망 연쇄 침투





협력사망 경유를 통한 공급망 연쇄 침투



연쇄 침투를 통한 지능형 보이스피싱 공격

✓ 시나리오 요약

파일 업로드 취약점을 통해 서버 초기 침투 후, 내부망 이동 및 n8n 취약점 악용으로 보안로직을 무력화하고 핵심 인프라를 장악, 이후 고객센터 XSS와 음성 데이터 분석을 통해 딥보이스 기반 자동화 피싱으로 실제 자금 탈취까지 이어지는 공격 시나리오

1

파일 업로드
취약점 이용

3

협력사망 침투 및
데이터 탈취

5

지능형 피싱 및
자금 탈취

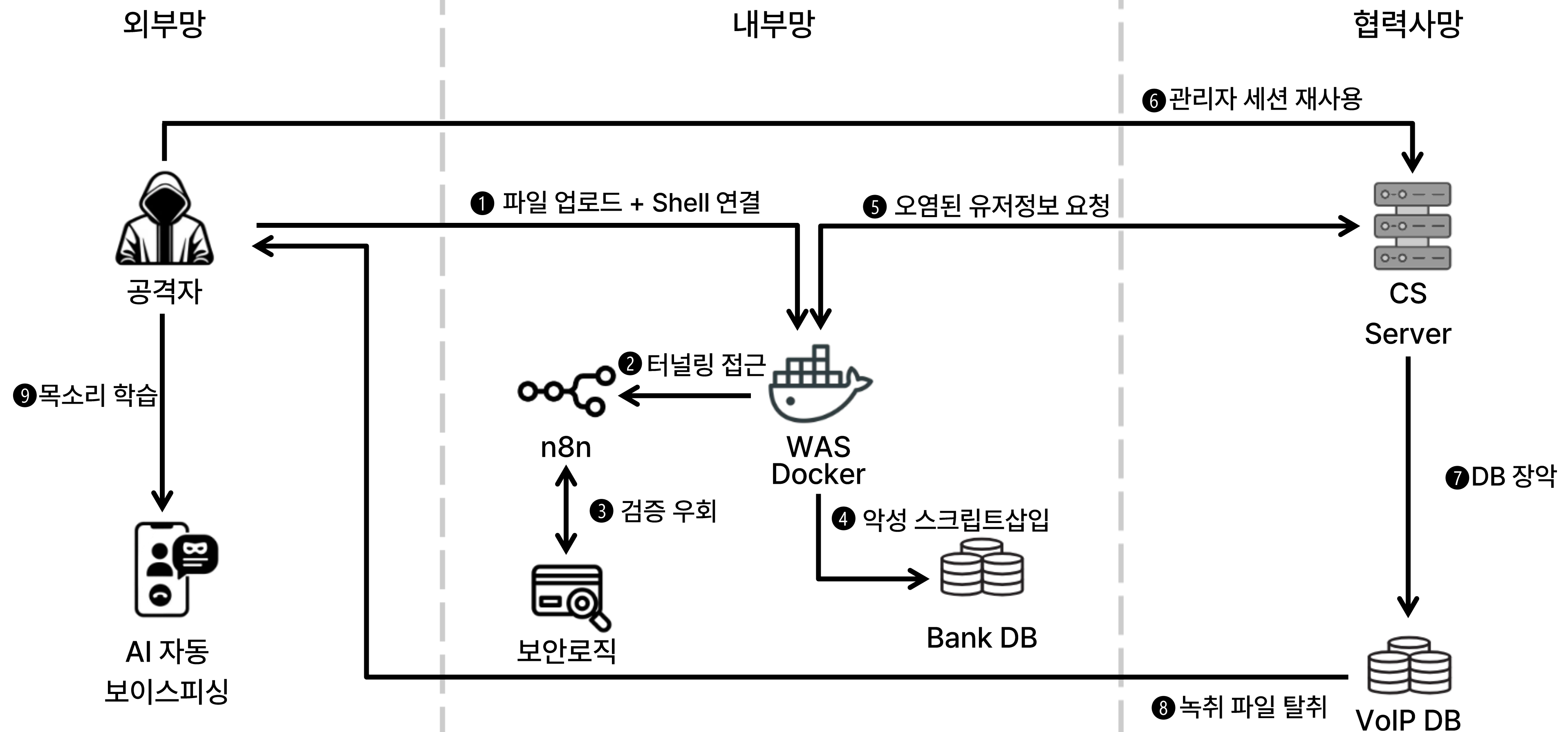
2

내부망 이동 및
보안로직 무력화

4

데이터 분석 및
딥보이스 모델 생성

연쇄 침투를 통한 지능형 보이스피싱 공격



시나리오 프로그램 환경

Spring Boot



버전 : 3.3.0

설명 : Java 기반의 Spring
애플리케이션 개발 프레임워크

n8n



버전 : 1.120.4

설명 : 앱, API를 시각적으로 연결하는
워크플로우 자동화 오픈소스 툴

취약점 : CVE-2026-21858

docker



버전 : 25.0.14

설명 : 어떤 환경에서든 동일하게 배포
및 실행 가상화 플랫폼

취약점 선정 배경



CVE-2026-21858

n8n 취약점 선정 개요

2026년 4월 기준으로 8개의 신규 CVE가 발행되는 등 치명적인 취약점이 지속적으로 보고
특히 이 중 4건은 CVSS 9.9점 이상, 나머지 4건은 7.5점 이상의 High 등급으로 평가됨
본 프로젝트에서 선정한 취약점은 최고점인 CVSS 10.0을 기록한 건으로, 인증되지 않은 외
부 공격자가 단지 네트워크 접근만으로 서버의 제어권을 완전히 탈취할 수 있다는 위험성을 직
접 시연하고 검증하기 위해 채택

취약점 설명

시스템이 수신 데이터의 Content-Type 헤더를 제대로 검증하지 않고 신뢰하여 파싱하는 설
계 결함 때문에 공격자가 조작된 HTTP 요청을 보내면 서버 내부의 임의 파일 경로에 접근할
수 있음

암호화 키 외 중요 정보를 탈취하여 관리자의 토큰을 생성 및 관리자의 토큰을 활용하여 RCE
가 가능한 취약점

| 연쇄 침투를 통한 지능형 보이스피싱 공격





| 연쇄 침투를 통한 지능형 보이스피싱 공격



CHAPTER —

04 보안 대책 및 향후 계획

- 보안 대책
- 향후 계획

시나리오 보안 대책

Zero Trust 기반 설계



원칙 1 절대 신뢰하지 말고 항상 검증 (Verify Explicitly)

사용자, 기기, 네트워크 위치에 관계없이 모든 접근 요청을 신뢰하지 않고, 지속적으로 신원과 권한을 확인

원칙 2 최소 권한 접근 허용 (Use Least Privileged Access)

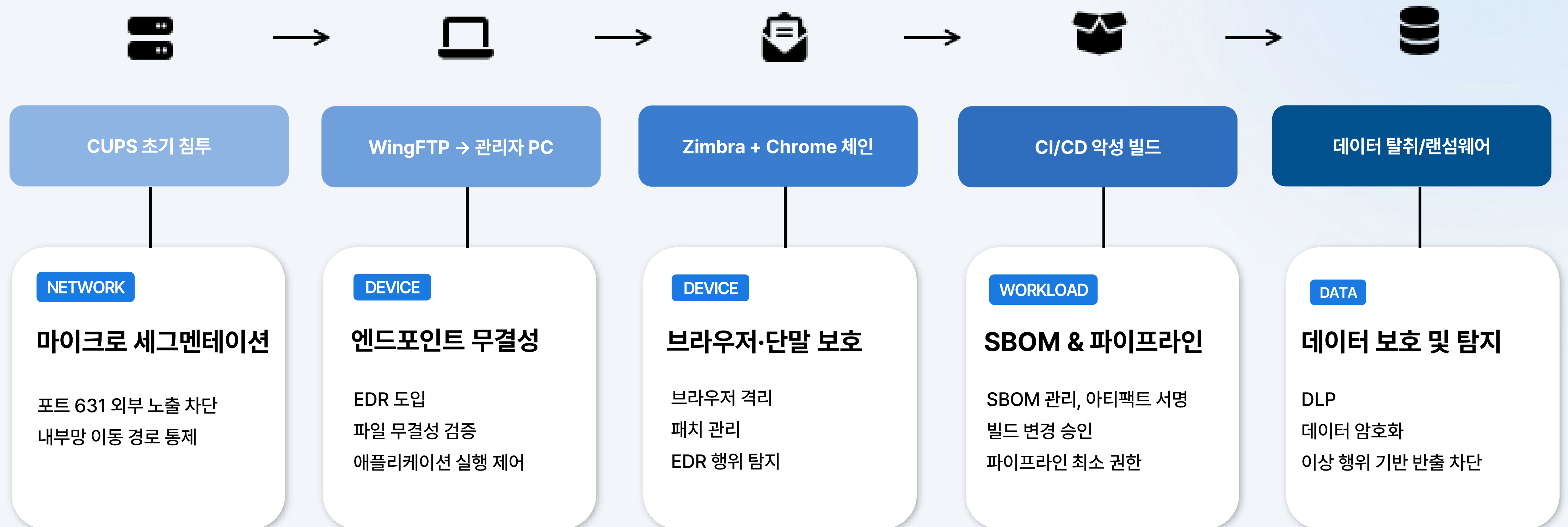
사용자가 업무 수행에 필요한 최소한의 리소스에만 접근하도록 제한하여, 사고 시 피해 범위를 최소화

원칙 3 침해 가정 (Assume Breach)

네트워크가 이미 침해되었다고 가정하고, 네트워크 분할로 피해 범위를 최소화하며, 위협 탐지 및 대응 자동화 체계 구축

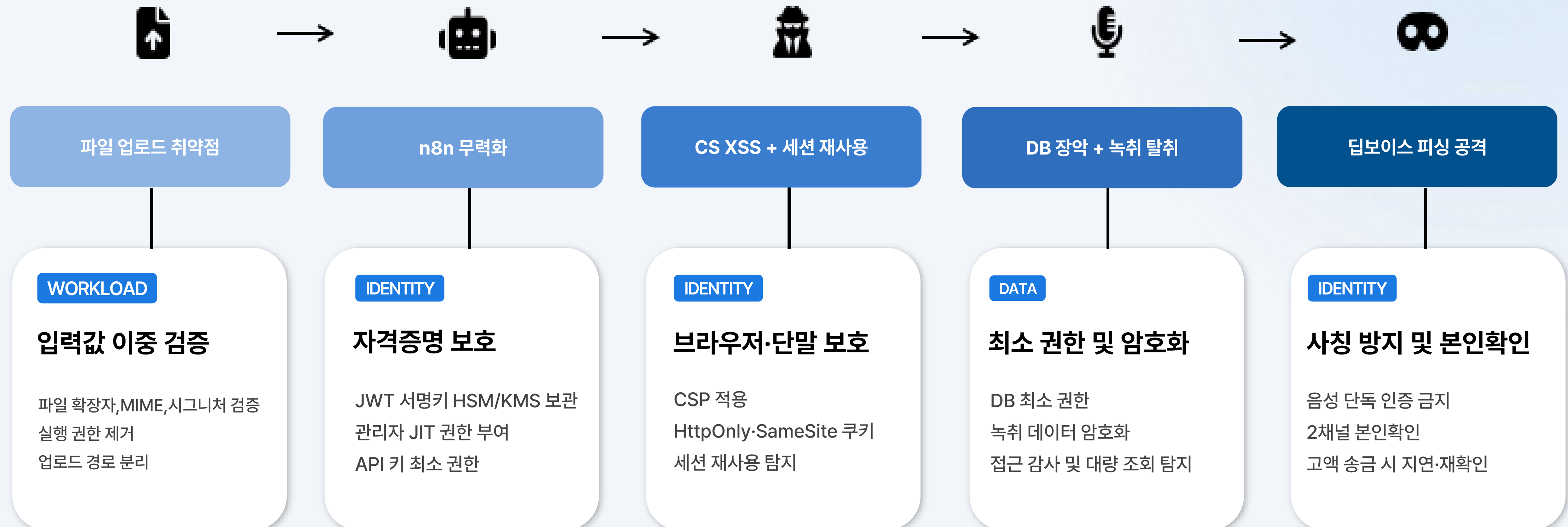
시나리오 보안 대책

Zero Trust 기반 설계 - 공급망 공격



시나리오 보안 대책

Zero Trust 기반 설계 - 보이스피싱



시나리오 보안 대책

EDR, XDR, MDR

EDR

엔드포인트 단의 악성 행위를
실시간으로 모니터링 및 격리

XDR

네트워크와 클라우드 등
전사적 영역으로 가시성을
확장하여 위협의 전체
맥락을 파악

MDR

자체적인 관제 역량이 부족할
경우에는, 전문적인 위협 헌팅과
24시간 모니터링을 제공하는
MDR 서비스를 통해 보안 공백을
메울 수 있음

시나리오 보안 대책

SBOM(소프트웨어 명세서)



SBOM이란?

최근 소프트웨어 개발 및 클라우드 인프라 구축 방식이 복잡해지면서, 시스템을 구성하는 코드, 라이브러리, 의존성 등을 명확하게 식별하고 추적하여 보안 취약점에 대응하기 위하여 제조업의 명세서 개념이 도입됨

SBOM은 SW 내부에 어떤 구성요소가 존재하는지 투명하게 식별하여, 사이버 위험을 신속하게 추적하고 관리하기 위한 핵심 도구

시나리오 보안 대책

SBOM(소프트웨어 명세서)

SBOM 도입의 필요성

Log4j와 같은 세계적으로 사용되는 라이브러리에 취약점이 발견됨
다른 프레임워크나 솔루션에 내장되어 있어, 소스코드 검색만으로는
시스템에 포함되어 있는지 탐지하기가 사실상 불가능했음

개발, 유통, 운영 전 단계에서 SW에 어떤 오픈소스나 타사
라이브러리가 포함되어 있는지 목록화하여 새로운 취약점이 발표될
경우, 해당 취약한 컴포넌트가 어느 시스템에 쓰이고 있는지 즉시
검색하여 패치를 적용함

앞선 시나리오들처럼 내부에 어떤 라이브러리가 숨겨져 있는지
모른다면 취약점 발생 시 대응 자체가 불가능함

SBOM 적용 방법

개발자가 코드를 빌드하는 시점에 명세서가 자동으로 생성되도록
CI/CD 파이프라인에 SBOM 추출 전용 플러그인을 연동함

SBOM 파일을 소프트웨어 구성 분석 도구를 이용하여, 전 세계
취약점 데이터베이스와 실시간으로 사용 중인 라이브러리 버전에
알려진 CVE가 존재하는지 스캔함

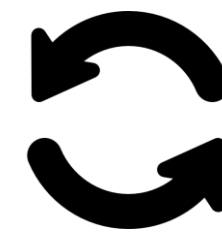
향후 계획



보안 적용

시나리오 모의해킹 결과를
바탕으로 도출된 방어 대책을 실제
시스템에 구축

식별된 주요 침투 지점을
우선순위로 두어 단계적인 시큐어
코딩 및 보안 패치 진행



침투 지점 재검증

기존 시나리오에서 확인된
취약점에 대해 보안 조치 적용 후
재침투 테스트 수행

발견한 취약점에 대해 보완 뿐만
아니라 실질적 방어 기능을 검증



취약점 추가 탐색

기존 시나리오 외 영역으로 범위를
확장하여 미탐지 취약점을 이용한
공격 탐색

동일 서비스 내 다양한 우회 경로
및 비정상 로직 시나리오 추가 확인

감사합니다.

Q&A

프로젝트 소감

✓ 팀장 백승빈

최신 트렌드를 공부할 수 있게 돼서 너무 재밌었고, 공부하는 방법을 알게 돼서 좋았습니다

✓ 팀원 최상훈

한정된 자원 속에서 직접 구축한 웹·앱 환경을 시나리오에 다 담지 못해 아쉽지만, 최신 트렌드를 직접 재현해 볼 수 있는 좋은 시간이었던 것 같습니다

✓ 팀원 서정우

처음으로 앱을 개발해 보고, 취약점들을 찾아 시나리오에 적용하고 직접 재현해보면서 최신 취약점들을 많이 접하는 좋은 기회였던 것 같습니다

✓ 팀원 손지선

6명의 인원으로 이 정도의 퀄리티를 구현한 것에 만족하며, 최신 보안 트렌드를 직접 경험하며 얻은 인사이트가 의미 있었습니다

✓ 팀원 성준모

팀 프로젝트 하면서 협업에 대해 이해도가 많이 높아졌고, V8 샌드박스 탈출 등과 같은 취약점에 대해 알게되어 좋았습니다

✓ 팀원 표민우

다음번에는 실제 금융 사이트에서 도전해 보겠습니다